Sardar Patel Institute of Technology

Bhavan's Campus, Munshi Nagar, Andheri (West), Mumbai-400058, India
(Autonomous College Affiliated to University of Mumbai)
TE (COMP+IT), Sem V, End Semester Exam
Sub: Cryptography and System Security, Code: CS307A
14th Nov 2022 (Re-exam)

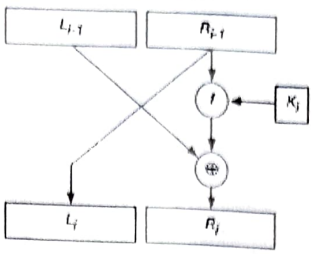
Marks: 60 **Duration: 2 Hrs**

Instruction: *Keep your answers clear and concise, and state all of your assumptions carefully. You will be graded for clarity and correctness. Answer **ALL** questions*

Qn		M(CO)
Q.1	Answer in brief any **five** of the following questions.	15(1,2,3)
a	Let us say that you are acting as an eavesdropper and observing an encrypted conversation between Sun and Moon. You notice that the prefixes of many of the cipher texts agree for several hundred bytes. In addition, these identical prefixes are always a multiple of 16 bytes long. However, you never observe two identical chunks of cipher text of any significant length following the identical prefixes. Show what cipher is being used, what mode of operation is being used, and what Sun and Moon are doing wrong?	3
b	In its next chip, Intel finds a way to make the stack non-executable. Does this solve the problem of buffer-overflow attacks? Explain briefly.	3
c	Why is it required that the private and public keys in RSA are relatively-prime to $\Phi(n)$? Suppose $\Phi(n) = 18$, choose two legal values for public and private keys (don't forget to include n).	3
d	Explain briefly similarities and differences between cryptographic hash functions and message authentication codes (MAC's).	3
e	Assume that system administrator in SPIT tries to setup email facility and he tries to use the simple mail transfer protocol (SMTP). Now this protocol is severely limited in terms of security. Hence what are the three main security threats system administrator should visualize as a part of system security? Justify identified threats.	3
f	Given an encryption function f(x), what kinds of trials can you do in order to check whether or not it achieves avalanche effect? Give example and explain. Also name the property of S-box and P-box that contributes to block cipher to achieve avalanche effect?	3
g	Draw a schematic view SSL protocols with suitable notaions. Identify the name of protocol for the following given functionality: 1) Establishes the security capability 2) Connection failure and illegal parameters 3) Provides confidentiality and message integrity.	3
h	Name mail access protocols and compare them.	

Q.2

a Recall that the heart of DES is a round of the form: 15(2,4) 8



Consider a simplified DES-like cryptosystem consisting of n such rounds, where the function f is defined by $f_K(X) = K \oplus X$. Here we assume that the key K is 32-bits long and that the same key is used at each round, that is, Ki = K for each round i. This system is used to encrypt a 64-bit message M as follows: L_0 is the leftmost 32-bits of M and R_0 is the rightmost 32-bits of M. The ciphertext $E_K(M)$ is Ln . Rn.

a) Describe how to decrypt messages encrypted with E_K.
b) Express L_1, R_1, L_2, and R_2 in terms of L_0, R_0, and K.
c) If we increase number of rounds then it will increase security or decrease security? Justify your answer by showing proof

b Consider the scenario where Sun receives a contract *m* from Moon, together with Moon's signature *s* on this document. Sun can then show to anyone that Moon has signed *m*. However this property is unsuitable for some applications, where Moon's commitment to *m* may be sensitive. For such situations, Neptune suggested *undeniable signatures*. An *undeniable signature* can only be verified with cooperation from the signer. To verify signature *s*, the verifier Venus engages in a protocol with Moon. Presume that Moon agrees to interact with Venus. So while running this verification protocol which equality does Venus then check to verify the signature? Draw suitable diagram and explain. Indicate clearly your assumption and parameters that you consider. 7

(*Hint:* a cyclic group G of prime order q with generator g and a hash function H with hash values in G. Each signer chooses a private key $x \in Z^*_q$ and computes the public key $X = g^x$. The signature on m is $s = (H(m))^x$).

Q.3

a Tom and Jerry proposed the following protocol in which A and B use a MAC algorithm, and a long-term shared key K_{AB} for this MAC, to agree on a session key K_S: 15(2,3) 8

$$1: A \rightarrow B : A; N_A$$
$$2: B \rightarrow A : N_B; \text{MAC } K_{AB}(N_A \| N_B \| B) \oplus K_S$$

a) Show how session key will be computed by A?
b) Explain for both A and B why they believe after a run that the session key K_S is fresh, i.e. that they are not subject to a replay attack which establishes some old session key.
c) Crackle simplifies the protocol as follows where he believes that since B chooses a new random key K_S in message 2, his nonce N_B is not necessary and he exchanges following protocol

$$1: A \rightarrow B : A; N_A$$
$$2: B \rightarrow A : MACK_{AB}(N_A \| B) \oplus K_S$$

If adversary gets hold of above simplified protocol then what he can do? Will B able to maintain communication with A or not? Justify your answer.

d) Do you think that there should be KDC or Third party required to improve the trust among A and B communication in a)? Yes or No? Justify.

b Gromit wants to send a Whatsapp message to Wallace securely, over an insecure satellite network. Gromit's device has a RSA public key K_G and matching private key V_G; likewise, Wallace's device has K_W and V_W. Let's design a cryptographic protocol for doing this, assuming both know each other's public keys. 7

Here is what Gromit's device will do to send the text message m:

1) Gromit's device randomly picks a new AES session key k and computes c' = RSA-Encrypt (K_W; k), c'= AES-CBC-Encrypt (k;m), and t = RSA-Sign(V_G; (c; c')).
2) Gromit's device sends (c; c; t) to Wallace's device.

And here is what Wallace's device will do, upon receiving (c; c' ; t):

1) Wallace's device checks that t is a valid RSA signature on (c; c') under public key K_G. If not, abort.
2) Wallace's device computes k' = RSA-Decrypt (V_W; c) and m' = AES-CBC-Decrypt (k'; c').
3) Wallace's device informs Bob that Gromit has sent message m'.

a) Does this protocol ensure the confidentiality of Gromit's messages? Why or why not?
b) Does this protocol ensure authentication and data integrity for every text message Wallace receives? Why or why not?
c) Suppose that Wallace is Gromit's financial advisor. Wallace hooks up the output of this protocol to an automatic financial trading service, so if Gromit sends a Whatsapp message 'Buy 1000 shares of L&T' using the above protocol, then this trade will be immediately and automatically executed from Gromit's account. From security point of view is this a good idea or not? At least give one proper reason that justifies your suggestion.
d) Explain how an adversary can recover the secret key when the signer reuses the same random number r for two different messages. State your assumptions also clearly (*Hint:* This is a digital signature scheme, so a message needs to be sent along with its signature).

Q.4 15(4)

a What is stateful and stateless firewall? Suppose a host-based firewall on a server keeps state for existing TCP connections—i.e., it tracks the state of TCP handshakes and only allow non-handshake packets on established connections. It must create a "SYN-received/SYN-ACK sent" queue until it sees a responding "ACK." Since the firewall queue is finite, it can be overwhelmed by a SYN-flood attack in which an attacker node sends many requests (SYN packets) under spoofed IP addresses, to cause the firewall to run out of queue space. 8

i) What will happen if, when the firewall runs out of queue space, it blocks further SYN packets?
ii) What will happen if, when the firewall runs out of queue space, it stops enforcing the restriction on non-handshake packets?

iii) Explain why an ACK time-out strategy will not work to solve this problem.

b Let us say that global corporation establishes gateways GW1 and GW2 at different branches. They enable machines in different branches to communicate securely over the Internet by implementing IPSec at the gateways only. That means that when a machine A inside the first network sends an IP packet to a machine B in the second network, the gateway GW1 intercepts the IP packet in transit and encapsulates it into an IPSec packet. At the other end, GW2 recovers the original IP packet to be routed in the second network to machine B. Which of the IPSec modes and protocols should be used if it was desired that no Internet eavesdroppers learn about the identities A and B of the communicating parties. Draw figure with suitable notations and explain, 7